

IoT Security Capstone

Experiment Results, Insights & Recommendations

[Joader Rashid] | [04/14/2026]

The Threat: Unprotected IoT Pipelines

What happens when MQTT messages travel without protection?

Eavesdropping

Intercepts data packets between sensor and broker, reading everything in plain text. Enables unauthorized surveillance and physical risks like exploiting a flood before the hotel knows.

Inject Fake Data

Spoofs a device or sends fake messages. False readings that hide real flooding make sensors unreliable and costing millions in damage and destroying trust in the system.

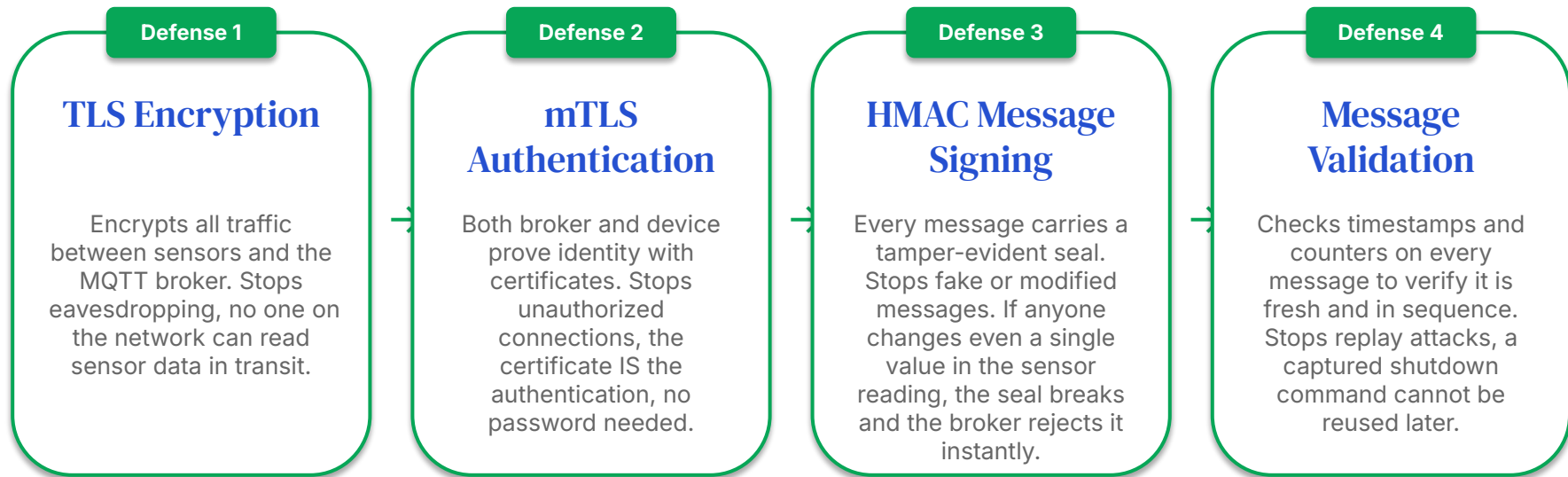
Replay Attack

Records a data packet and reuses it later. Replaying a captured shutdown command can cut off sensors at will causing financial damage and real physical risk.

Without encryption, authentication, or message verification, any device on the network can read, fake, or replay MQTT messages — turning a water monitoring system into a liability.

Defense Architecture: Four Layers of Protection

Each layer catches what the previous one can't.

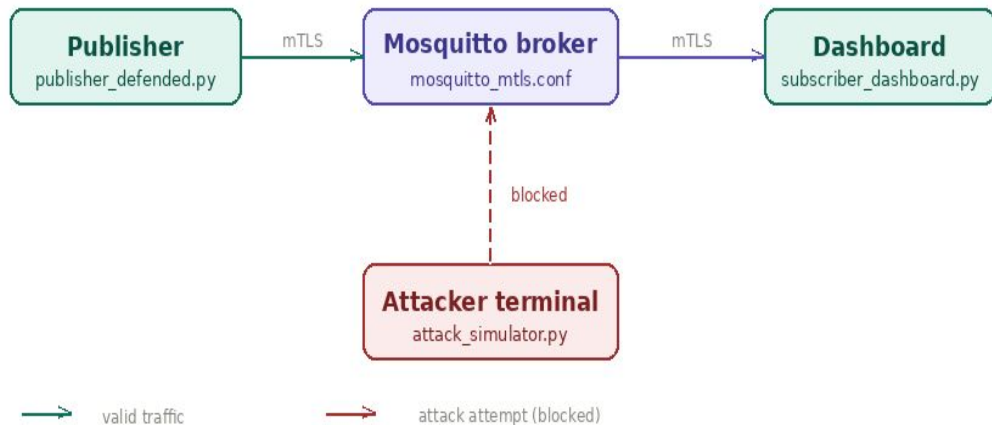


Remove any one layer and attackers find the gap. TLS without auth lets anyone connect encrypted. Auth without ACLs lets authenticated devices do anything. ACLs without validation can't stop replayed messages. All four layers are required.

Experiment Setup: Three-Phase Attack Simulator

A controlled test against the live pipeline to verify every defense works.

Setup Process



- Started the Mosquitto broker and opened the live dashboard in the browser to monitor incoming sensor data in real time.
- Ran the attack simulator in a separate terminal, attempting three attacks: eavesdropping, injecting fake data, and replaying old commands.
- Watched the dashboard light up red as each attack was detected and blocked, while the terminal logs showed which defense stopped it.

Attack Results: Every Attack Blocked

Which defense caught each attack phase — and why it works.

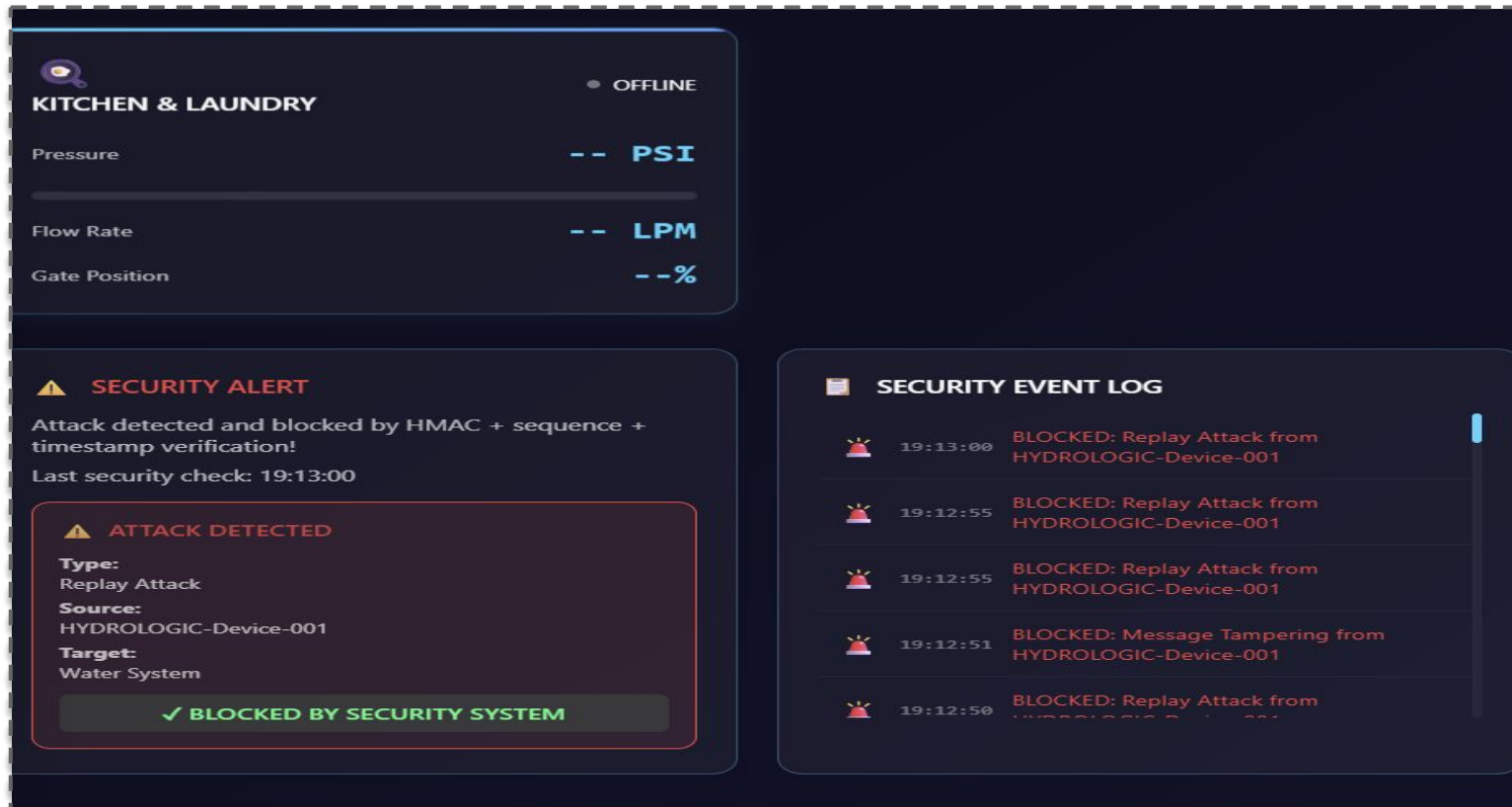
Attack Phase	What the Attacker Tried	Defense That Caught It	Why It Works
Phase 1: Eavesdrop	Subscribed to all topics using <code>mosquitto_sub</code> to read sensor data	TLS encryption	All traffic is encrypted in transit, so even if intercepted the data is unreadable
Phase 2: Inject	Injected fake sensor readings pretending to be GM-HYDROLOGIC-01	mTLS device certs	Without a valid client certificate the broker rejected the connection entirely
Phase 3: Replay	Captured a real message and re-sent it to the broker	Message Validation	The message was flagged as a duplicate or expired and rejected by the dashboard



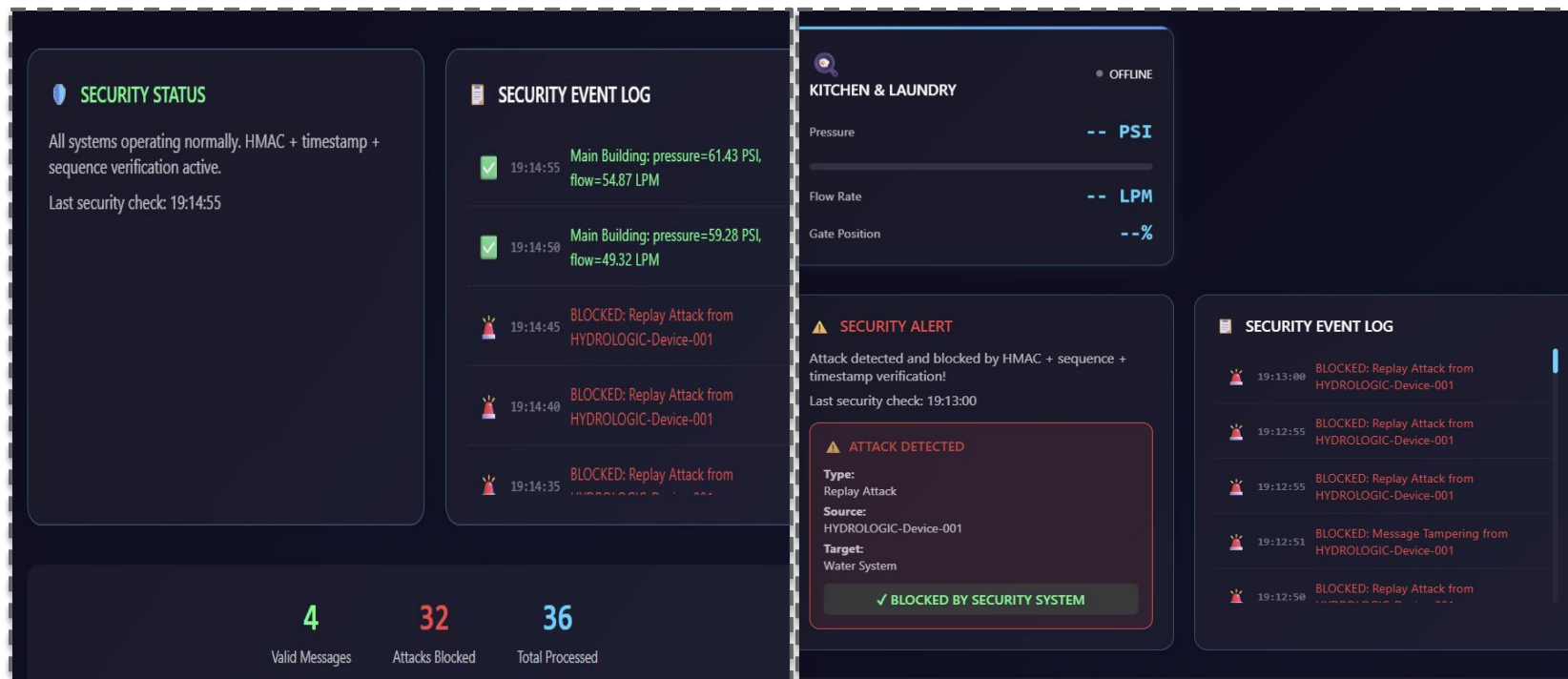
Result: 0 attacks succeeded | 100% blocked

Dashboard: Attack Detected

Red alerts, shaking zone cards — every attack caught in real time.



Stats: Attacks Blocked



Joarder's Security Hub



Key Insights

What this experiment revealed about IoT security.

1

No single defense is enough

What I learned is that each defense has a blind spot on its own. What surprised me is how easy it was to bypass one layer but how quickly all four layers together blocked every single attack with no exceptions.

2

Real Attacks are not as complex as you think

What worked better than expected was how quickly the dashboard detected each attack in real time. If I were doing this again I would have set up logging from the start so I could track every rejected message from the beginning of the experiment.

3

Security's affect on speed is negligible

I expected adding security layers to slow things down noticeably. What surprised me was that all three message protections together added less than one millisecond per reading, completely invisible to hotel operations.

4

Access Control Lists (ACLs)

After running the attack simulator I realized that even an authenticated device could still publish to topics it should not have access to. If I were doing this again I would add topic based access controls so each device can only communicate on its own channel.

Recommendations for Grand Marina

What should happen next to secure the IoT infrastructure at scale.

1

Deploy all four defenses immediately

The protected system is already built and tested so there is no delay. Grand Marina should switch on TLS, mTLS, HMAC signing, and timestamp validation across all three HYDROLOGIC devices in the main building, pool wing, and kitchen right away.

2

Add topic based access controls

Grand Marina should restrict each HYDROLOGIC device so it can only publish to its own sensor topic. This prevents a compromised device from sending commands or interfering with other devices on the network.

3

Set up a permanent security dashboard

Grand Marina should deploy a real time monitoring dashboard so hotel staff can see the status of all three devices at a glance and receive instant alerts when a message is rejected, without needing to read technical logs.

4

Schedule regular security audits

Grand Marina should conduct security reviews every six months to check device certificates, scan for unauthorized devices on the network, and confirm all protections are still active and up to date as the hotel's IoT infrastructure continues to grow.

Questions?
